# การวิเคราะห์และออกแบบยกระดับระบบ Family Health CRM ฉบับสมบูรณ์

## 1. การวิเคราะห์จุดแข็งและจุดที่ต้องปรับปรุงจากเอกสารต้นฉบับ

จากการอ่านและวิเคราะห์เอกสาร `SUMMARY.txt` อย่างละเอียด แนวคิดของ **Family Health CRM** มีความชัดเจนและมีศักยภาพสูงมากในตลาดประเทศไทยที่กำลังก้าวเข้าสู่สังคมผู้สูงอายุระดับสุดยอด (Super-Aged Society) จุดเด่นที่สุดของเอกสารฉบับนี้คือการแยกความแตกต่างระหว่าง **"แอปบันทึกสุขภาพส่วนบุคคล"** กับ **"ระบบประสานงานดูแลสุขภาพครอบครัว (Care Coordination + Granular Consent)"** ได้อย่างเฉียบคม

อย่างไรก็ตาม เมื่อพิจารณาในมุมของการนำไปสร้างผลิตภัณฑ์จริง (Production-grade) ทั้งในแง่ประสบการณ์ผู้ใช้ (UX) สำหรับคนไทย สถาปัตยกรรมซอฟต์แวร์ (Software Architecture) และโมเดลธุรกิจ ยังมีจุดที่สามารถปรับลดความซับซ้อนที่ไม่จำเป็น (Over-engineering) และเติมเต็มช่องโหว่สำคัญเพื่อให้ระบบใช้งานได้จริงและเติบโตได้เร็วขึ้น

**จุดแข็งของแนวคิดปัจจุบัน (Strengths)**

- **แก้ปัญหาตรงจุด (Right Problem-Solution Fit):** เปลี่ยนจากระบบ "1 บัญชี = 1 คนไข้" เป็นระบบศูนย์กลางครอบครัวที่กำหนดสิทธิ์รายบุคคลได้ ตอบโจทย์ลูกหลานวัยทำงานที่ต้องดูแลพ่อแม่แยกบ้านกัน
- **โครงสร้างความปลอดภัยระดับมาตรฐานสากล:** การแยก Domain ระหว่าง CRM, Health Record และ Authorization/Consent ออกจากกัน รวมถึงการใช้หลักการปฏิเสธไว้ก่อน (Deny by Default) และการบังคับผ่าน AI Context Gateway สอดคล้องกับกฎหมาย PDPA หมวดข้อมูลอ่อนไหว (Sensitive Data มาตรา 26)
- **เลือก Tech Stack เหมาะสมกับ MVP:** การใช้ Modular Monolith (Laravel 13 + PostgreSQL + Redis + Flutter/Angular) ช่วยลดภาระการดูแลระบบ (DevOps Overhead) ได้ดีกว่าการทำ Microservices ตั้งแต่วันแรก

**จุดเสี่ยงและช่องโหว่ที่พบในแผนเดิม (Gaps & Risks)**

- **Care Task State Machine ซับซ้อนเกินไปสำหรับผู้ใช้ทั่วไป:** ในเอกสารกำหนดสถานะไว้ถึง 7–9 ขั้นตอน (`Draft → Open → Assigned → Accepted → In Progress → Completed → Verified`) ในชีวิตจริง ลูกหลานหรือผู้ดูแลผู้สูงอายุที่บ้านจะไม่กดเปลี่ยนสถานะทีละขั้นในการป้อนยา 1 มื้อ เพราะสร้างภาระการกด (Click Fatigue) จนเลิกใช้งานในที่สุด
- **ขาดแนวคิด "Managed Profile" (โปรไฟล์ผู้พึ่งพิงที่ไม่มีสมาร์ทโฟน):** เอกสารเน้นว่าแต่ละคนถือข้อมูลของตัวเองแล้วกดแชร์สิทธิ์ (Self-sovereign) แต่ในความเป็นจริง ผู้ป่วยติดเตียง ผู้สูงอายุสมองเสื่อม หรือเด็กเล็ก ไม่สามารถสมัครบัญชีหรือกดยินยอม (Consent) เองได้
- **ขาดกลไก "Break-Glass Emergency Access" (การเข้าถึงข้อมูลยามฉุกเฉิน):** หากตั้งค่าสิทธิ์แบบ Deny by Default อย่างเคร่งครัด แล้วผู้สูงอายุหมดสติถูกส่งห้องฉุกเฉิน (ER) โดยมีญาติคนอื่นที่ไม่ได้ถูกเปิดสิทธิ์เต็มรูปแบบพาไปโรงพยาบาล ระบบจะต้องมีกลไกปลดล็อกข้อมูลสำคัญชั่วคราว (เช่น ประวัติแพ้ยา โรคประจำตัว ยาละลายลิ่มเลือด) พร้อมแจ้งเตือนเจ้าของสิทธิ์ทันที
- **นำ LINE Integration ไปไว้ Phase 2 ช้าเกินไป:** สำหรับครอบครัวไทย LINE คือหัวใจของการสื่อสาร หาก Phase 1 บังคับให้ทุกคนในบ้านต้องโหลดแอป Flutter เท่านั้น อัตราการมีส่วนร่วม (Adoption Rate) ของผู้สูงอายุจะต่ำมาก

**ตารางเปรียบเทียบแนวทางเดิมในเอกสาร vs แนวทางที่ปรับปรุงใหม่**

| มิติการออกแบบ | แนวทางเดิมใน SUMMARY.txt | แนวทางที่ปรับปรุงและออกแบบใหม่ | ข้อดีของการปรับปรุง |
|---|---|---|---|
| **การจัดการบัญชีผู้สูงอายุ** | สมาชิกแต่ละคนสร้างบัญชีของตนเองแล้วแชร์สิทธิ์ให้คนอื่น | รองรับทั้ง **Self-Managed Account** และ **Dependent/Proxy Profile** (ลูกหลานสร้างและดูแลแทนผู้สูงอายุ) | แก้ปัญหาผู้สูงอายุใช้แอปไม่เป็นหรือเป็นผู้ป่วยติดเตียง |
| **สถานะงานดูแล (Care Task)** | 7 ขั้นตอนตายตัว (`Draft` ถึง `Verified`) ทุกงาน | แบ่งเป็น **Fast-Track (2 ขั้นตอน: `Pending → Done`)** สำหรับงานทั่วไป และ **Strict Mode (มี `Verified`)** เฉพาะงานความเสี่ยงสูง | ลดความรำคาญของผู้ใช้ ทำให้บันทึกงานรายวันได้ใน 1 คลิก |

| | | | |
|---|---|---|---|
| **การเข้าถึงยามฉุกเฉิน** | ไม่ได้ระบุ (ใช้ Deny by Default ตลอดเวลา) | เพิ่ม **Emergency Medical Card & Break-Glass Protocol** พร้อม Audit Log แจ้งเตือนทุกคนในบ้าน | ช่วยชีวิตผู้ป่วยหน้าห้องฉุกเฉินได้ทันท่วงทีโดยไม่เสียความปลอดภัย |
| **ช่องทางการใช้งาน (Touchpoint)** | Mobile App (Flutter) + Web (Angular) ใน Phase 1, LINE ใน Phase 2 | **Hybrid Touchpoint ตั้งแต่ Phase 1:** แอปหลักสำหรับ Care Manager + **LINE OA/ LIFF** สำหรับผู้สูงอายุและญาติทั่วไป | ทลายกำแพงการโหลดแอปใหม่สำหรับผู้สูงอายุในไทย |
| **การบันทึกข้อมูลสุขภาพ** | กรอกตัวเลขความดัน น้ำตาล น้ำหนัก ด้วยมือ | เพิ่ม **OCR / AI Vision อ่านหน้าจอเครื่องวัดความดันและซองยา** (ผ่าน Context Gateway) | ลดความผิดพลาดจากการพิมพ์ตัวเลขผิด (Human Error) |

---

## 2. การออกแบบ Product & UX/UI ใหม่ให้เหมาะสมกับครอบครัวไทยที่สุด

เพื่อให้ระบบไม่เป็นเพียง "ฐานข้อมูลที่กรอกยาก" แต่เป็น "ผู้ช่วยประจำบ้าน" ควรปรับการออกแบบประสบการณ์ผู้ใช้เป็น **3 บทบาทหลัก (Tri-Persona Experience)** ดังนี้

### 2.1 โครงสร้างบทบาทผู้ใช้งาน (User Personas & Interfaces)

- **Care Coordinator (ลูกหลานที่เป็นหัวเรี่ยวหัวแรงหลัก):** ใช้งานผ่านแอปมือถือ (Flutter) หรือเว็บ (Angular) แบบเต็มรูปแบบ เพื่อตั้งค่าตารางยา จัดการสิทธิ์ ดูกราฟแนวโน้ม และเตรียมเอกสารไปพบแพทย์
- **Active Senior / Caregiver (ผู้สูงอายุที่ยังช่วยเหลือตัวเองได้ หรือผู้ดูแลรับจ้าง):** เน้นใช้งานผ่าน **โหมดหน้าจอย่อ (Simplified UI / Elder Mode)** ตัวอักษรใหญ่ ปุ่มกดขนาดใหญ่ไม่เกิน 3 ปุ่มต่อหน้า หรือใช้งานผ่าน **LINE Official Account (Rich Menu)** เพื่อกดยืนยันว่า "กินยาแล้ว" หรือ "ส่งรูปหน้าจอเครื่องวัดความดัน"
- **Passive / Dependent Member (ผู้สูงอายุติดเตียง / เด็กเล็ก):** ไม่ต้องล็อกอิน ใช้ระบบ **Proxy Account** ที่ผู้แทนโดยชอบธรรม (Legal Guardian) เป็นผู้ถือครองและจัดการสิทธิ์แทนตามกฎหมาย

### 2.2 การปรับปรุงระบบ Care Task State Machine (Adaptive Workflow)

แทนที่จะบังคับใช้ State Machine 7 ขั้นตอนกับทุกงาน ให้แบ่งระดับความเข้มงวดตาม **ประเภทความเสี่ยงของงาน (Task Criticality Level)** ดังนี้

- **ระดับที่ 1: Routine Care Task (งานกิจวัตรทั่วไป เช่น เตือนกินยาวิตามิน วัดความดันประจำวัน)**
  - **Flow:** `Scheduled → Completed (หรือ Skipped/Missed)`
  - **ตัวอย่างการใช้งาน:** เมื่อถึงเวลา 08:00 น. ระบบแจ้งเตือนที่มือถือหรือ LINE ผู้ดูแลกดปุ่ม "กินยาแล้ว" เพียงปุ่มเดียว ระบบบันทึกเวลาและชื่อผู้กดทันที ไม่ต้องกดรับงาน (`Accepted`) หรือกดกำลังทำ (`In Progress`)
- **ระดับที่ 2: Delegated Logistics Task (งานมอบหมายที่ต้องมีคนรับผิดชอบชัดเจน เช่น พาพ่อไปเจาะเลือด ซื้อยาที่หมด)**
  - **Flow:** `Open → Assigned → Accepted → Completed (หรือ Escalated หากไม่มีคนรับภายในเวลาที่กำหนด)`
  - **ตัวอย่างการใช้งาน:** ลูกสาวสร้างงาน "พาคุณแม่ไปตรวจตา วันที่ 25 ต.ค." มอบหมายให้น้องชาย หากน้องชายไม่กด `Accepted` ภายใน 24 ชั่วโมง ระบบ Escalation จะแจ้งเตือนกลับไปยังกลุ่มครอบครัวเพื่อหาคนแทน
- **ระดับที่ 3: High-Risk Clinical Task (งานหัตถการหรือยาความเสี่ยงสูง เช่น ฉีดอินซูลิน ยาละลายลิ่มเลือด ทำแผลกดทับโดยพยาบาลพาร์ทไทม์)**
  - **Flow:** `Assigned → In Progress → Completed (แนบภาพถ่าย/ค่าตัวเลขบังคับ) → Verified (ลูกหลานตรวจรับงาน)`
  - **ตัวอย่างการใช้งาน:** พยาบาลดูแลที่บ้านฉีดอินซูลิน ต้องกรอกค่าน้ำตาลปลายนิ้วก่อนฉีดและถ่ายรูปยืนยัน (`Completed`) จากนั้นลูกหลานได้รับแจ้งเตือนและกดรับทราบผลการดูแล (`Verified`)

---

## 3. การออกแบบสถาปัตยกรรมระบบและระบบสิทธิ์ (Architecture & Access Control)

โครงสร้าง **Modular Monolith บน Laravel 13** ที่เลือกไว้ในเอกสารมีความเหมาะสมมาก แต่เพื่อให้โค้ดไม่พันกัน (Spaghetti Code) และพร้อมแยกเป็น Microservices ในอนาคตเมื่อระบบขยายตัว ควรออกแบบโครงสร้างโมดูลภายในและระบบสิทธิ์ให้ชัดเจนดังนี้

### 3.1 การแบ่ง Bounded Contexts ใน Laravel Modular Monolith

แต่ละโมดูลต้องสื่อสารกันผ่าน **Internal Service Contracts (Interfaces) และ Domain Events** ห้ามเขียน Query ข้ามตารางของโมดูลอื่นโดยตรง (No Cross-Module Joins)

- **Module 1: Identity & Workspace (`app/Modules/Workspace`)** จัดการบัญชีผู้ใช้ การสร้างครอบครัว การเชิญด้วย QR Code และความสัมพันธ์เครือญาติ
- **Module 2: Authorization & Consent Engine (`app/Modules/Consent`)** หัวใจหลักในการตรวจสอบสิทธิ์ (Policy Enforcement Point) จัดการการให้สิทธิ์ เพิกถอนสิทธิ์ และบันทึก Immutable Audit Log
- **Module 3: Health Vault (`app/Modules/HealthRecord`)** จัดเก็บข้อมูลสัญญาณชีพ (Vital Signs), ประวัติการแพ้ยา, โรคประจำตัว, ผลแล็บ และไฟล์เอกสารทางการแพทย์ (เข้ารหัสระดับฟิลด์หรือระดับไฟล์)
- **Module 4: Care Coordination CRM (`app/Modules/CareCrm`)** จัดการตารางกินยา นัดหมายแพทย์ การมอบหมายงาน (Care Tasks) และระบบแจ้งเตือน (Escalation Engine)
- **Module 5: AI Context Gateway (`app/Modules/AiGateway`)** ตัวกลางคัดกรองข้อมูล ปิดบังข้อมูลส่วนบุคคล (Anonymization) และควบคุม Prompt ก่อนส่งไปยัง LLM ภายนอก

### 3.2 การออกแบบโมเดลสิทธิ์แบบผสมผสาน (Hybrid ReBAC + RBAC + Scope)

เพื่อความแม่นยำและประสิทธิภาพในการ Query บน PostgreSQL ควรออกแบบโครงสร้างการตัดสินใจให้สิทธิ์ (Authorization Decision Flow) โดยแยก **"ความสัมพันธ์ในบ้าน"** ออกจาก **"สิทธิ์ในข้อมูลสุขภาพ"** อย่างเด็ดขาด

| องค์ประกอบของสิทธิ์ | คำอธิบาย | ตัวอย่างค่าในระบบ |
|---|---|---|
| **Subject (ผู้ขอเข้าถึง)** | ผู้ใช้งานที่กำลังเรียก API หรือผู้ดูแลที่ได้รับมอบหมาย | `user_id: 102` (ลูกสาว), `user_id: 205` (ผู้ดูแลรายวัน) |
| **Target Subject (เจ้าของข้อมูล)** | สมาชิกในครอบครัวที่เป็นเจ้าของข้อมูลสุขภาพนั้น | `patient_profile_id: 50` (คุณพ่อ) |
| **Resource Domain (หมวดหมู่ข้อมูล)** | ประเภทของข้อมูลสุขภาพที่อนุญาตให้เข้าถึง | `vitals`, `medications`, `mental_health`, `lab_results`, `tasks` |
| **Action Permission (การกระทำ)** | สิทธิ์การกระทำที่แยกย่อยตามมาตรฐาน v1.0.0 | `read`, `create`, `update`, `export`, `delegate` |
| **Temporal & Condition Scope** | เงื่อนไขเวลาและบริบทของการให้สิทธิ์ | `valid_from`, `valid_until` (เช่น ให้สิทธิ์พยาบาลดูได้เฉพาะกะเวลาทำงาน หรือเฉพาะ 7 วัน) |

### 3.3 กลไกการเพิกถอนสิทธิ์ทันที (Instant Revocation) และ Break-Glass

- **การเพิกถอนสิทธิ์ที่มีผลทันที (Zero-Latency Revocation):** เมื่อเจ้าของข้อมูลกดเพิกถอนสิทธิ์ (Revoke Consent) ระบบจะยิง Event ไปล้าง Permission Cache ใน **Redis** ของคู่ความสัมพันธ์นั้นทันที (`DEL auth:consent:{patient_id}:{actor_id}`) ทำให้ API Call ถัดไปถูกบล็อกในระดับ Middleware ทันทีภายในเสี้ยววินาที แม้ Access Token (Sanctum) ของผู้ใช้นั้นจะยังไม่หมดอายุก็ตาม
- **กลไก Break-Glass (โหมดฉุกเฉินทางการแพทย์):**
  - สมาชิกในครอบครัวที่ได้รับการตั้งค่าเป็น `Emergency Contact` สามารถกดปุ่ม **"ขอเข้าถึงข้อมูลฉุกเฉิน (Emergency Override)"** ได้เมื่อผู้ป่วยเข้าโรงพยาบาลกะทันหัน
  - ระบบจะบังคับให้ระบุเหตุผลและยืนยันตัวตนซ้ำ (OTP/PIN) จากนั้นจะเปิดให้ดูเฉพาะ **ข้อมูลช่วยชีวิตฉุกเฉิน (Critical Summary: กรุ๊ปเลือด, ประวัติแพ้ยา, โรคประจำตัว, ยาปัจจุบัน)** เป็นเวลาจำกัด (เช่น 4 ชั่วโมง)
  - ระบบจะส่งแจ้งเตือนระดับสูงสุด (Critical Alert) ไปยังเจ้าของข้อมูลและสมาชิกหลักทุกคนในครอบครัวทันที พร้อมบันทึกลงใน Audit Log ที่ลบไม่ได้

---

## 4. การออกแบบ AI Context Gateway และความปลอดภัยตามมาตรฐาน PDPA

การระบุในเอกสารว่า "AI ต้องไม่เข้าถึงฐานข้อมูลโดยตรง แต่ต้องผ่าน Context Gateway" เป็นแนวคิดที่ถูกต้องที่สุดในทางวิศวกรรมซอฟต์แวร์ ควรออกแบบสถาปัตยกรรมของ **AI Context Gateway** เป็น 5 ขั้นตอน (5-Stage Pipeline) ดังนี้

### ขั้นตอนการทำงานของ AI Context Gateway

`User Request → [1. Policy & Consent Verifier] → [2. Scoped Data Fetcher] → [3. PII Scrubber & Anonymizer] → [4. Clinical Guardrail Prompting] → [5. Audit & Output Filter] → User`

- **ขั้นที่ 1: Policy & Consent Verifier (ตรวจสอบสิทธิ์ 2 ชั้น)**
  - ชั้นแรก: ตรวจสอบว่าผู้เรียกใช้ (User) มีสิทธิ์ `health.*.read` ในข้อมูลของเป้าหมายหรือไม่
  - ชั้นที่สอง: ตรวจสอบว่าเจ้าของข้อมูลได้เปิดสวิตช์ยินยอมให้นำข้อมูลเข้าสู่การประมวลผลด้วย AI (`consent.ai_processing.enabled = true`) หรือไม่ หากปิดอยู่ ระบบจะปฏิเสธทันทีโดยไม่ดึงข้อมูล
- **ขั้นที่ 2: Scoped Data Fetcher (ดึงข้อมูลเท่าที่ได้รับอนุญาต)**
  - ดึงข้อมูลเฉพาะช่วงเวลาที่กำหนด (เช่น 30 วันล่าสุด) และดึงเฉพาะหมวดหมู่ที่ผู้ใช้นั้นมีสิทธิ์เห็น เช่น หากผู้ดูแลมีสิทธิ์เห็นแค่ "ความดันและตารางยา" แต่ไม่มีสิทธิ์เห็น "ประวัติจิตเวช" ตัว Gateway จะดึงมาเฉพาะความดันและตารางยาเท่านั้น
- **ขั้นที่ 3: PII Scrubber & Pseudonymization (การตัดข้อมูลระบุตัวตนก่อนส่งออกนอกเซิร์ฟเวอร์)**
  - ก่อนส่ง Payload ไปยัง LLM API (เช่น OpenAI, Claude หรือ Gemini API) ระบบต้องตัดชื่อ-นามสกุลจริง เลขบัตรประชาชน เบอร์โทรศัพท์ ชื่อโรงพยาบาล และที่อยู่ออกทั้งหมด
  - แทนที่ด้วยรหัสสมมติและข้อมูลเชิงสถิติ เช่น เปลี่ยนจาก "นายสมชาย ใจดี อายุ 72 ปี รพ.ศิริราช" เป็น "Patient_A, เพศชาย, ช่วงอายุ 70-75 ปี"
- **ขั้นที่ 4: Clinical Guardrail & Doctor Prep Prompting (การควบคุมขอบเขตคำตอบ)**
  - บังคับ System Prompt ไม่ให้ AI วินิจฉัยโรค (No Diagnosis) หรือสั่งปรับลดโดสยาเองโดยเด็ดขาด
  - เน้นให้ AI ทำหน้าที่ 2 อย่างคือ: **(1) สรุปแนวโน้มสัญญาณชีพและการกินยาในรูปแบบที่แพทย์อ่านเข้าใจได้ใน 30 วินาที (Doctor-Ready One-Page Summary)** และ **(2) แนะนำรายการคำถามที่ลูกหลานควรถามแพทย์ในการนัดหมายครั้งถัดไป**
- **ขั้นที่ 5: Output Validation & Immutable Audit Log**
  - ตรวจสอบผลลัพธ์จาก AI แนบคำเตือนทางการแพทย์ (Medical Disclaimer) และบันทึก Hash ของ Prompt, รายการข้อมูลที่ถูกดึง และชื่อผู้เรียกใช้ลงในตาราง `ai_audit_logs`

### ตัวอย่างการแปลงข้อมูลผ่าน AI Context Gateway

- **ข้อมูลดิบในฐานข้อมูล (ห้ามส่งให้ AI โดยตรง):**
  - ชื่อ: นางสมศรี มีสุข (เลขบัตร 3-1005-xxxxx-xx-x) โทร 081-xxx-xxxx
  - ประวัติ: ความดันวันที่ 20 ต.ค. 165/95 mmHg, ลืมกินยา Amlodipine 5mg 3 วันติดกัน, มีบันทึกส่วนตัวเรื่องอาการซึมเศร้า (ล็อกสิทธิ์เฉพาะลูกสาว)
- **ข้อมูลที่ผ่าน AI Context Gateway (เมื่อลูกชายกดขอสรุปไปพบแพทย์):**
  - ข้อมูลส่งออก: `Subject: Female, Age_Group: 75-80 | Allowed_Scopes: [Vitals, Medications] | BP_Trend_7d: Avg 158/92 mmHg (Max 165/95 on Day -2) | Med_Adherence: Amlodipine 5mg missed 3 consecutive doses` (สังเกตว่าไม่มีชื่อจริง และไม่มีข้อมูลอาการซึมเศร้าที่ลูกชายไม่มีสิทธิ์เข้าถึง)

---

## 5. การออกแบบฐานข้อมูลและเทคนิคป้องกันข้อผิดพลาด (Technical Best Practices)

เพื่อให้การพัฒนาด้วย **Laravel 13 + PostgreSQL** มีความเสถียรสูงสุดและผ่านเกณฑ์การทดสอบความปลอดภัย (Authorization Baseline v1.0.0) แนะนำให้วางโครงสร้างทางเทคนิคดังนี้

### 5.1 มาตรฐานการออกแบบฐานข้อมูลสำหรับระบบสุขภาพ (PostgreSQL)

- **ใช้ UUID v7 เป็น Primary Key ทั้งหมด:** ห้ามใช้ Auto-increment ID (`1, 2, 3...`) กับตารางข้อมูลสุขภาพและเอกสาร เพื่อป้องกันช่องโหว่การเดาเลข ID ข้ามบัญชี (IDOR - Insecure Direct Object Reference) โดย UUID v7 มีข้อดีคือเรียงตามเวลา (Time-ordered) ทำให้ Index ของ PostgreSQL ทำงานได้เร็วเทียบเท่า BigInt
- **ใช้ PostgreSQL Row-Level Security (RLS) ร่วมกับ Application Policy:** นอกจากการเช็กสิทธิ์ด้วย Laravel Policy/Gate แล้ว สามารถตั้งค่า Session Variable ใน PostgreSQL เพื่อให้มั่นใจว่าไม่มี Query ใดหลุดรอดการกรองสิทธิ์ไปได้

- **ตาราง Audit Log แบบ Append-Only:** ตาราง `security_audit_logs` ควรตั้งสิทธิ์ระดับ Database User ให้ทำได้เฉพาะ `INSERT` และ `SELECT` เท่านั้น (ห้าม `UPDATE` หรือ `DELETE` แม้แต่ระดับ Admin ของแอป) และเก็บค่า Hash ต่อเนื่องกัน (Hash Chaining) เพื่อใช้เป็นหลักฐานทางกฎหมายตาม PDPA ได้จริง

**5.2 ฟีเจอร์ "One-Page Doctor Summary (QR / PDF ชั่วคราว)"**

- **ปัญหาหน้าห้องตรวจ:** เวลาลูกหลานพาผู้สูงอายุไปหาหมอ หมอมีเวลาตรวจเฉลี่ยเพียง 3–5 นาทีต่อคน หมอจะไม่เลื่อนดูแอปมือถือของคนไข้ทีละหน้า
- **แนวทางออกแบบ:** สร้างฟีเจอร์ **"สร้างใบสรุปสำหรับแพทย์ (Doctor Visit Brief)"** ที่กดปุ่มเดียวแล้วระบบสร้างหน้าสรุป 1 หน้ากระดาษ A4 (หรือเปิดผ่าน QR Code แบบหมดอายุใน 30 นาที) แสดงกราฟความดัน/น้ำตาล 30 วันล่าสุด, เปอร์เซ็นต์ความสม่ำเสมอในการกินยา (Medication Adherence %), อาการผิดปกติที่บันทึกไว้ และรายการยาปัจจุบันที่กินอยู่จริง ฟีเจอร์นี้จะเป็นจุดขายสำคัญ (Killer Feature) ที่ทำให้ทั้งแพทย์และครอบครัวรักแอปนี้ทันที

---

## 6. การวิเคราะห์โมเดลธุรกิจ การตั้งราคา และแผนพัฒนา (Business Model & Roadmap)

**6.1 การวิเคราะห์และปรับโครงสร้างราคา (Pricing Strategy)**

ในเอกสารเสนอราคาทดสอบไว้ที่ **฿179 – ฿699 ต่อเดือน** ซึ่งเป็นช่วงราคาที่สมเหตุสมผลสำหรับกลุ่มครอบครัวชนชั้นกลางขึ้นไปที่มีผู้สูงอายุต้องดูแล แต่เพื่อให้เกิดการบอกต่อและลดแรงเสียดทานในการตัดสินใจซื้อ ควรแบ่งโครงสร้างแพ็กเกจให้ชัดเจนตามคุณค่าที่ได้รับ (Value Metric) ดังนี้

| แพ็กเกจ | ราคาแนะนำ | กลุ่มเป้าหมาย | ฟีเจอร์หลักที่ได้รับ |
|---|---|---|---|
| **Free (เริ่มต้น)** | ฿0 | ผู้ใช้ทั่วไป / ทดลองใช้ | 1 Workspace, สมาชิกดูแลร่วมได้ 2 คน, บันทึกความดัน/น้ำตาลพื้นฐาน, เตือนยาพื้นฐาน, ประวัติย้อนหลัง 30 วัน |
| **Family Care (แนะนำ)** | ฿199 / เดือน (หรือ ฿1,990 / ปี) | ครอบครัวที่มีผู้สูงอายุหรือผู้ป่วยเรื้อรัง 1–2 คน | สมาชิกครอบครัวสูงสุด 6 คน, ระบบมอบหมายงาน (Care Tasks) + แจ้งเตือนผ่าน LINE, ดูประวัติย้อนหลังไม่จำกัด, รายงานสรุปไปพบแพทย์ (Doctor Summary PDF), AI สรุปผลสุขภาพ 15 ครั้ง/เดือน |
| **Care Plus / Multi-Home** | ฿499 / เดือน | ครอบครัวใหญ่ หรือมีการจ้างผู้ดูแล/พยาบาลพาร์ทไทม์ | สมาชิกและผู้ดูแลไม่จำกัด, **ระบบจำกัดสิทธิ์ผู้ดูแลภายนอกรายชั่วโมง/กะ (Temporary Caregiver Access)**, โหมดตรวจสอบงานเข้มงวด (Verified Tasks), AI อ่านซองยา/หน้าจอเครื่องวัดความดันไม่จำกัด, Audit Log เต็มรูปแบบ |

**6.2 การปรับปรุงแผนการพัฒนา (Optimized Phased Roadmap)**

เพื่อให้เข้าสู่ตลาดได้เร็ว (Time-to-Market) และพิสูจน์คุณค่าของผลิตภัณฑ์ (Product-Market Fit) ได้ตั้งแต่ระยะแรก แนะนำให้ปรับลำดับความสำคัญของ Roadmap ใหม่ดังนี้

- **Phase 0: Security & Authorization Foundation (สัปดาห์ที่ 1–3)**
  - วางโครงสร้าง Modular Monolith, ระบบ Identity, Workspace, Dependent Profile และ Consent Engine

    - เขียน Automated Security Tests (ทดสอบ IDOR, Cross-workspace isolation, Instant Revocation) ให้ผ่าน 100% ตามที่ระบุในเอกสารก่อนเริ่มทำหน้าจอฟีเจอร์สุขภาพ
- **Phase 1: Core MVP + LINE Notification (สัปดาห์ที่ 4–10)**
    - ระบบบันทึกสัญญาณชีพ (ความดัน, น้ำตาล, น้ำหนัก), ประวัติแพ้ยา, ตารางเตือนกินยา และ Medical Timeline
    - ระบบ Care Task แบบ Fast-Track (กดยืนยันง่าย) **พ่วงกับการแจ้งเตือนและกดรับทราบผ่าน LINE OA ทันทีตั้งแต่ Phase 1** เพื่อให้ผู้สูงอายุและสมาชิกในบ้านใช้งานได้ทันทีโดยไม่ต้องรอ Phase 2
    - ฟีเจอร์ส่งออก **Doctor Visit Summary (1-Page PDF)** สำหรับพกไปโรงพยาบาล
- **Phase 2: Advanced Care Coordination & Caregiver Delegation (เดือนที่ 3–4)**
    - ระบบมอบหมายงานแบบเต็มรูปแบบ (Delegated & High-Risk Tasks พร้อมระบบ Escalation เมื่อไม่มีคนรับงาน)
    - ระบบมอบสิทธิ์ชั่วคราวให้บุคคลภายนอก (เช่น พยาบาลพิเศษ หรือศูนย์ดูแลผู้สูงอายุ) พร้อมระบบ Break-Glass Emergency Access
- **Phase 3: AI Context Gateway & Smart Health Assistant (เดือนที่ 5–6)**
    - เปิดใช้งาน AI Context Gateway เต็มรูปแบบ
    - ฟีเจอร์ AI สรุปแนวโน้มสุขภาพและเตรียมคำถามพบแพทย์, AI อ่านค่าจากรูปถ่ายหน้าจอเครื่องวัดความดันและฉลากยา (OCR) เพื่อลดภาระการพิมพ์

---

## 7. สรุปภาพรวมและข้อเสนอแนะเชิงกลยุทธ์ (Executive Summary)

เอกสาร `SUMMARY.txt` มีรากฐานด้านสถาปัตยกรรมความปลอดภัยและการแบ่งขอบเขตข้อมูล (Domain Driven Design & Security Baseline) ที่แข็งแกร่งมากอยู่แล้ว การจะยกระดับให้ระบบนี้ประสบความสำเร็จสูงสุดในตลาดจริง สรุปหัวใจสำคัญที่ควรปรับปรุงได้ 4 ข้อดังนี้

1. **ง่ายสำหรับคนหน้างาน แต่รัดกุมอยู่เบื้องหลัง (Simple UX, Strict Backend):** ลดขั้นตอนการกดเปลี่ยนสถานะงาน (State Machine) ของงานประจำวันให้เหลือเพียง 1 คลิกสำหรับผู้ดูแล แต่คงความเข้มงวดของระบบตรวจสอบสิทธิ์ (ReBAC) และ Audit Log ไว้เบื้องหลังทั้งหมด
2. **รองรับผู้สูงอายุที่ไม่ได้ถือสมาร์ทโฟน (Proxy Profile & LINE-First):** เพิ่มโหมดโปรไฟล์ผู้พึ่งพิง (Dependent Profile) และเชื่อมต่อ LINE OA ตั้งแต่ระยะแรก เพื่อแก้ปัญหาคนในครอบครัวไม่ยอมโหลดแอปใหม่
3. **เติมเต็มระบบฉุกเฉินและหน้าห้องตรวจ (Break-Glass & 1-Page Doctor Summary):** เพิ่มกลไกปลดล็อกข้อมูลช่วยชีวิตยามฉุกเฉินภายใต้การบันทึก Audit Log และสร้างใบสรุป 1 หน้ากระดาษสำหรับยื่นให้แพทย์ในห้องตรวจ ซึ่งจะสร้างความแตกต่างจากคู่แข่งในตลาดอย่างชัดเจน
4. **ปกป้องความเป็นส่วนตัวสูงสุดเมื่อใช้ AI (Zero-PII AI Gateway):** บังคับใช้กระบวนการตัดข้อมูลระบุตัวตน (Pseudonymization) ใน AI Context Gateway ทุกครั้งก่อนส่งข้อมูลออกไปยัง LLM ภายนอก